

2025年6月7日 星期六 / 大雨

CISSP备考指南 (根据2025年06月05日的备考笔记补充整理)

流程概述:

1. 官网注册，购买认证考试，并线上付费(Visa、Mastercard、AMEX卡均可);
2. 预约考场，时间，语言，地点；中文形式的考试在每个季度的最后一个月。
3. 携带身份证和信用卡，提前半小时入场等待，入场前会要求关闭手机，手表等电子设备；即8点的考试，应在7:30到达考场。如无信用卡，可采用护照或驾照。考试需要提供两种不同的身份认证方式；注意信用卡后面应签考生姓名；
4. 按照考试要求，会询问身份信息，录入左右手掌纹，拍照等，根据指示即可，之后会将随身携带物品放入储物柜，随身仅保留身份证。手串首饰也不允许携带；
5. 接下来会进行二次检查，考生翻出全身口袋，简单拍打外套，脚踝处，以示并无其他物品携带。如衣服具备帽子，亦需要戴下帽子以示干净；
6. 随后陪考员陪同进入考场，并登陆考试系统。考场一般具备无死角监控及单隔间。注意任何行动均需提前举手。尤其是考试结束，必须提前举手示意。陪考员会进行后续动作。中间需要去洗手间也需要举手；

考前建议:

1. 摒弃技术思维，多用管理思维。考虑治理，风险，合规，业务连续性，成本等因素；
2. 阅读考试大纲，识别自己的短板；
3. 练习大量习题，应该只做高质量的习题。但不要指望考试时遇到大面积的题目。实测刷了3500题左右，仅见到1题完全一样。
注意：OSG的习题就是高质量的习题。所有答案以OSG 10th为准；考试的备考资料，常见有AllinOne和OSG两套书，建议使用OSG 10th (中文仅有第9版)；
4. 不仅需要知道某题为什么对，还有知道其他项为什么错！
5. 不会的题先用排除法，例如端口号的题目，排除已知的非题目，例如：XXX端口为什么协议，或者XXX协议使用什么端口；XXX法案适用适用什么场景等；
6. 练习时对于部分争议性的题目，不必要过于纠结。确保理解问题考察的点，及答案的点即可。因为最终考的是总体分数，而不是这一题。
7. 如果路程较远，建议入住考点附近；调整好状态很重要；不要着急；

做题建议：

刷第一遍题库A，识别出错题，整理出错题集A1，刷错题集A1，继续迭代刷错题集A2，之后刷题库A，循环。保持每天刷一定量的新题，并把前一天的错题刷掉。尤其注意审题，详细见下述几点：

1. 问题的格式及措辞是需要关注的(还要注意双否定)，例如：

- XXX不是一个问题？XXXX不是一个缺点？
- 哪个机制在XXX方面的作用最小？
- 哪种缓解措施的效果最差？
- 哪些不是自动发送到XXXX的特权管理活动？
- 执行正确的异常处理？ 还是没有执行正确的异常处理？
- XXX 提供了适当的安全性？
- 不是XX应该推荐的最佳实践
- 哪项任务不是由系统管理者时效性的
- 不是常用的单点登陆方案

2. 注意关键词语

- Most/Highest/Least/Top/Must/Should/First/Second/Last/Fastest
- Reason/Effective/Purpose/Function/Control/Solution/Factor/Common

例如：问某个Function是阻止未授权访问，但如果问其Purpose则答案是确保机密性。看题问的Function还是Purpose

3. 注意词语陷阱

- 哪里不能实现纵深防御？如果答案出现Nowhere，Nowhere的地方不能实现。
- 词语A和词语B代表同一件事情，同一个语义。例如Identities等于Entities；Internetwork层就是network层；Containment阶段就是Mitigation阶段；Enumeration就是Scanning阶段；

4. 一定要看双语的翻译，中文的CISSP考试中存在许多的翻译错误。

- 错误1：数据保留的实际英文原文是 Data Protection；
- 错误2：合法使用的实际英文原文是 used lawful scenario； // 大概是这个意思
- 错误3：首席信息安全官的实际英文原文是CIO； //这个最离谱

5. 判断A，B，C，D的答案中，如果两个答案都似乎符合题目，看A是不是包含B，如果是，A更重要。

知识点强化：

该部分根据备考过程中，针对易错题目，及知识点的整理。

1. SOC2审计的最重要因素是：定期的测试和监控控制项；为什么选择外在的审计，因为外面的审计更加的专业，富有经验。这叫结构化审计。为什么又不选外部了。因为内部审计的成本更低。内部审计又叫非结构化审计。为什么内部审计没有发现问题，外部审计发现问题？因为内部审计只按照最低级别进行管理计。
2. SOC1、2、3审计的区别。外部云厂商提供SOC3；Soc2里包含了Soc3，Soc1里面含有财务控制。Soc2不仅看控制有效还会看运营有效。
3. 重点关注是考访问控制还是考认证，考认证的时候是强化认证方式，还是强化密码策略。强化密码策略时，不要选MFA。强化密码策略的时候，有复杂度优先选复杂度，没有复杂度再选长度。拉长长度可以有效抵御暴力破解；
4. 对云上提供数据安全的访问，则启用MFA优先；保护数据的安全，那启用加密。
5. 问最快的方式，就别考虑成本，选拉专线。如问有效的方式，则要考虑成本。
6. SSO只是IDAAS下的一个Component，而非Common Type。IDAAS的Common Type是IAM。RBAC是符合IAM的最佳实践，SSO不是。
7. 键盘上输入内容这是Type1类认证，Something You Know。键盘上输入的行为方式是Type3，Some You Are，是一种生物行为。
8. Single-Use的Password一般可以认为是令牌。智能卡内可能含有证书，但是令牌肯定不含有。
9. 生物认证关注指标是CER，(结合了FAR和FRR)，出了问题，不要去调整FAR和FRR的阈值，也别调灵敏度。增加一个新的认证因素即可。如果还不行呢？考虑更换新的生物认证系统。
10. 访问控制背后关注的是机密性，是访问控制管理的子集。
11. 风险管理指导安全架构设计，安全架构设计指导安全运营。
12. CVSS中最重要的指标是BaseScore
13. 提高XX标准下的Compliance最好是找外部人士进行，因为更客观。
14. Clark-Wilson模型和Bible模型的区别在于，支持SOD(权责分离)。
15. EOL：不卖了；EOS：不售后支持了。EOS阶段也就该更换了；如果legacy设备多，那就重新划分Segment，然后移进去。如果设备少，就一个那就换新的。
16. 移动设备的问题是增加了数据泄露的风险。
17. 安全基线用在哪些系统是Scoping，这些系统用哪些基线是Tolerating。
18. 数据中心，冷通道吸入，暖通道排出。
19. 对供应商最低的安全标准要求：和你当前所在的企业一样，不能再低了。

20. 评估信心叫定性，评估数量是定量。
21. 日志是Secondary Evidence，属于间接证据。
22. 电子取证的过程要确保数据的保存和安全，即便数据已经过保存期。
23. 802.11g 是 2.4GHZ，802.11a 是 5 GHZ。
24. 一个员工转岗之后，容易发生权限蔓延。使用RBAC模型授予对应职位的权限即可。权责分离是为了避免一个任务出错（也避免欺诈），不同的阶段给不同的人去操作。双人控制防止滥用职权，尤其针对高风险操作。例如财务支付的审批，密钥制作。
25. 强制休假利于发现企业内部的欺诈行为。
26. 螺旋模型的四个阶段，分别是规划，风险分析，工程和评估。注重快速迭代应该选敏捷开发模型，在一个Scrum中Developer Owner负责开发，文档整理和Sprint冲刺。Product Owner代表客户利益。注意敏捷开发电子化沟通和文档化并不是最重要的。快速交付才是。注重稳健的开发就选瀑布模型，是线性开发的模型。前期会有完善的文档设计。还有一种模型是可重叠的瀑布模型。XP（极限编程）的模型要比敏捷开发的周期还要短。敏捷一般2-4周，XP一般1-2周。
27. 增加SYN的Cookie数量能够有效防止SYN Flooding
28. 如果查找软件Key Logger，就看系统内安装的程序和进程。如果查找硬件Key Logger，就去物理机器上查看有没有接入异常的外部设备。
29. 启用新的BCP时应该删除旧的BCP，BCP计划中响应灾难的第一步应该是：建立全员通讯。
30. 软件更新属于Patch Management，Patch Management属于预防性的控制措施。而Backup才是纠正性的控制措施。仅靠补丁无法确保安全。
31. 如果需要监控员工的活动，应该关注UEBA类产品，关注主机类活动，选择EDR。看题目问什么。
32. 威胁是一个潜在的有害事件；风险是威胁被利用造成了损失；漏洞是资产在管理运营等过程中的缺陷和弱点。
33. 风险评估是主动识别潜在漏洞和风险的措施，威胁评估是指识别和分析组织中威胁的过程。风险管理框架的主要目标是保护资产的机密性，完整性，可用性。
34. 数据处理是看怎么用，数据存储是看怎么保存。如果一个数据存起来为了审查用户的行为，这个就是关注数据处理。
35. MITM (Man In The Middle)是中间人攻击，但是有一个叫Meet In the Middle的是密码学攻击。
36. 查看Netflow是最简单的方法，查看SIEM是最佳的方法。SIEM的日志要一致，需要NTP提供统一时间戳。
37. 输入验证为了检查格式，限制检查是为了检查区间和边界。
38. 根据云上使用的产品去判断云上用的什么类型的服务。IAAS，PAAS，SAAS。
39. Evidence Collection也叫Artifact Gathering

40. 渗透测试的主要目的是识别系统中的漏洞，而非验证安全控制。安全控制评估过程才是为了验证安全控制的有效性。如果企业短期面临了一些安全事件，好的方式是请第三方进行渗透测试，并进行常规的安全评估。但定期的安全评估通常不会专门针对内部威胁。应对内部威胁的有效方式是背调。
41. 旋转门是Fail Open的设计机制
42. 安全审计的频率是更重要的衡量网络安全的指标，应对Security Breach的最有效的方式也是常规的周期性安全审计。
43. 安全评估的过程： Establish Security Requirement, Identify Asset & Value, Conduct Risk Analysis, Develop & Implement Security Controls.
44. 控制分为Logical Control和Physical Control。Technical Control也叫Logical Control, Administrative Control也称之为Procedure Control
45. SLR是SLA的一部分，关注可用性和性能。
46. 桌面演练是基于讨论的，因此场景选择更重要。
47. 数据保留政策中最重要的部分是考虑哪类数据被存储
48. 应急响应最重要的部分是阻止事件未来的损害
49. 虚拟化系统更易受到攻击的主要原因是多虚拟机分类资源
50. PAP以明文的形式传递密码，非常不安全。
51. 日志便于问责，签名便于不可否认。同时看日志比看CCTV录像有效
52. 端口安全可以防止CAM表泛洪
53. developer发起的控制有change control和release control，user发起的为change control
54. VRF可以实现虚拟路由和转发
55. 使用蓝牙用于非机密活动，而不是使用蓝牙的强加密用于机密活动。类似的道理，不要加强无用的东西在机密的事情上，看似合理，实际错。
56. Power-on-self-test的第一步是Self-Test， 不是Power On。
57. 最高级别的DAC是Owner- Controlled Access
58. 使用SOAR的主要益处是提高威胁响应的效率，并不是自动化。自动化只是其中一个组件，而且简单的自动化的流程无法提高安全防御的效率。
59. 全面中断的测试可能面临未知问题，最有效的测试方式应该是测试系统备份和DCP
60. MFA可以提高安全性，但是要看题目是问提高认证强度，还是强化密码的策略。MFA不强化密码策略。
61. 内存中保护未授权的敏感数据访问用加密的方式
62. 尽职调查的过程中最重要的指标是获得的数据的指标
63. IT安全审计中的重要因素是暴露的风险等级
64. RDP的主要安全问题是未授权访问

65. Security Policy的主要目的是保护资产安全，提供指导。而且Policy优先，如果问什么是控制资产的物理及逻辑访问控制。最好的不是访问控制列表，而是访问控制策略。
66. 三方软件安装到一个安全环境中，要优先考虑的是和现有系统的兼容性
67. 安全分析师识别漏洞，安全工程师关注安全控制
68. SDSec/SDS的最重要部分是： Adopting a Risk-Based Approach to Security Decision-Making
69. 数据向云迁移过程的指标应该是最短停机时间
70. 负责的一般都是高管（所有者），如果是数据，则是数据所有者。谁负责，就要获得谁的审批，以及获得谁的支持。
71. Network Architecture的key factor是Network Segment
72. 客户端向TGS发送Authenticator，向AS发送User ID。ST代表主体有权访问对象
73. Swip是磁条卡，Hold是Contactless卡，Insert是Contact卡。这类题目直接读英文，中文翻译无法判断是什么卡片。翻译都是刷卡
74. Hypervisor Mode 被称为-1模式
75. Recovery团队负责让备用站点尽快启动并运行，根因分析发生在Mitigation阶段，Incident Response最后一步是Lessons Learned
76. 注意区分培训意识和问责，有些情况只培训不解决问责。
77. 能登陆不代表有权限访问敏感数据。默认分配是No Access
78. Context-based关注上下文，有时间或者有场景因素。Content-Based基于特定内容
79. Verification是由第三方独立评估，可以被许多不同组织信任。Assurance代表了组织对控制措施满足安全要求的信心。系统获得认证，意味着获得了所有者的认可。
80. 静态NAT，有多少Private IP就要有多少个Public IP，1比1的关系，NAT池，N个Private IP动态的从M个Public IP中获得。N小于M。PNAT，1个Public IP用于N个Private IP
81. 访问控制列表是1-1的单对单。访问控制矩阵是1-N的，例如1-1-1，有多个列。
82. 使用 密码进行身份认证，不是使用用户名。
83. fuzzing testing归属于Black testing
84. 组件接口测试关注不同单元间数据传递，系统间接口测试关注整体。浏览器测试，为了测试接口。
85. 使用正式请求批准来访问数据
86. 漏洞扫描发现漏洞，端口扫描发现端口
87. 人短缺的原因可能是人为，环境，自然等因素。
88. 考率成本时，如果是采纳一个新的，未经证实的技术，高昂的成本是考虑的因素。但如果是因为核心安全受到威胁考虑新技术，则成本为次要因素。

英语单词列表

应该首先根据自己的英文水平，测试出在CISSP考试题目中所有不符合当前英文水平的单词，然后迅速过一遍。之后在第二次过一遍。并争取每天刷题前，保证所有的单词过一遍。同时如遇到不认识的单词，记下来。下次继续。 以下为部分个人认为需要关注的单词：

Confinement: 禁闭	Patent: 专利
Data Retention: 数据保留	Transposition cipher: 转置密码
Ultimate: 终极	Substitution cipher: 替换密码
Steganography: 隐写术	TEMPEST: 电磁屏蔽
Proximity Card: 感应卡	Supreme Court Rulings: 最高法院裁决
Consolidation: 整合，合并	Compendium of Laws: 法律汇编
Inherent risk: 固有风险	Arbitrating disputes about criticality: 仲裁关于关键性的争议
Residual risk: 残余风险	Avenues of protection: 保护途径
Disseminated: 传播，散布	Augment existing security controls: 增强现有的安全控制
Disclosed confidential information: 泄露机密信息	Divestiture: 剥离，资产剥离
CALEA: 通信协助执法	Shoulder Surfing: 肩窥
Tangible: 有形的	Eavesdropping: 窃听
Least likely: 最不可能的	Newly appointed IT manager: 新任命的IT经理
Capacitance: 电容	Repudiation: 否认
Examining: 检查	Tampering: 篡改
Deterrent: 威慑的	Elevation of privilege: 权限提升
Pursue legal action: 采取法律行动	Promiscuous: 混杂的
Imposes a standard of care: 施加注意标准	Encapsulated: 被包装的
Due diligence: 尽职调查	Hand geometry: 掌纹
Due Care: 应有注意	Key Stroke: 按键
Consolidation of security function: 安全职能的整合	Financial Penalty: 经济处罚
Protection of Intellectual Property: 知识产权的保护	Objecting to the exception: 反对例外
Burden of proof: 举证责任	Remorse: 悔恨

Negligence: 疏忽	Depreciated Cost: 折旧成本
Vendor Neutral: 供应商中立	Designating: 指定, 选派
Testimony: 见证	Evacuating: 撤离
Consistence Corroborative Evidence: 构成佐证	Meticulously: 小心谨慎的
Intimidation: 恐吓	Divestitures: 资产剥离
Deemed Inadmissible: 被视为不予受理	Rigorous: 严格的
Inadvertently: 无意间	Proactive: 进取
Circumstances: 规避	Bolster: 增强
Consequence: 后果	Resistance: 抵抗力
Innately: 天生	Pitfalls: 陷阱
Permutation: 排列	Surveillance: 监视
Noninvasive: 非侵入性	Contemplating: 打算
Thermostat: 恒温器	Misinterpreted: 误解
Mandatory: 强制的	Pursuant to search warrant: 根据搜查令
Vascular Pattern: 血管图案	Disposal: 处理
Gait: 步态	Key escrow: 密钥托管
Arrested for participation in an embezzlement schema: 因参与贪污被捕	Decommissioned: 退役
Disguise the fraud for months: 掩盖长达数月的欺诈行为	Degaussing: 消磁
Mandatory Vacation: 强制休假	Reciprocal: 互惠的
Turnstiles: 旋转门	Deemed: 视为
Incorporate: 纳入	Spear phishing: 鱼叉式网络钓鱼
Mantrap: 陷阱	Vishing: 语音网络钓鱼
Interference: 干扰	Spiral: 螺旋
Emphasizes: 强调, 突出	Inadmissible: 不可接受
Paramount: 必须的, 最重要的	Entrapment: 诱捕 (不可作为证据)
Cybersquatting: 域名抢注	Enticement: 引诱 (可以作为证据)
Neglecting: 忽视, 疏忽	Incarceration: 监禁
Aftermath: 后来	
Impersonating: 冒充	

资源列表

Tips: 使用Google Gemini 2.5 Pro 进行翻译, 识别错题的知识点, 总结错题。个人一共是刷了三套题库1900 (SkillCertPro, 19.9\$) +1300 (OSG Tests 4th) +484题 (淘宝购买31¥, 后发现实际为ExamTopics)。题库可以帮助识别考试知识短板, 不要期望碰到原题。另外处于题库质量, 如果不同题库的答案不同, 应以OSG为准。

- (必看, 强烈推荐) 官方考试指南: [ISC2 CISSP Official Study Guide 10th.pdf](#)
- (必看, 强烈推荐) 官方习题册: [ISC2 CISSP Official Practice Tests 4th.pdf](#)
- (必看, 官网下载) 中文版考试大纲: [CISSP Exam Outline May 2021 Chinese.pdf](#)
- (必看, 官网下载) 英文版考试大纲: [CISSP Exam Outline April 2024 English.pdf](#)
- (可选, 推荐浏览) [Destination CISSP Mind Map](#)
- (可选, 推荐练习) [SkillCertPro的CISSP题库](#)
- (不推荐) [ExamTopics的CISSP题库](#)